SOFTWARE REQUIREMENTS SPECIFICATION

Intelligent Phishing and Scam Detection Platform

Project ID: T3-PS1
Revised baseline: Version 1.1 (proposed)
Document date: 10 October 2026
IEEE 830-style structure

Status: Draft for stakeholder review. Requirements are proposed unless explicitly approved. No implementation, model performance, or test result is claimed by this document.

Document Control

Field	Value
Title	Revised SRS, Requirements Traceability, Decision Register, and Acceptance Test Suite
Project	T3-PS1 — Intelligent Phishing and Scam Detection Platform
Version	1.1 proposed revision; Version 1.0 source preserved as baseline
Status	Draft for stakeholder approval
Basis	Original 22-page SRS and the supplied master audit prompt
Standards note	IEEE 830-1998 is used as a legacy structural guide; this document does not claim formal certification.
Change summary	Clarified MVP boundaries, priority semantics, scoring and uncertainty, URL/QR safety, API behavior, ML evaluation, security, traceability, decisions, and hackathon readiness.

Audit Basis and Limitations

The supplied source material contains the original SRS and a master prompt that groups improvement opportunities into F-01 through F-120 ranges. It does not contain a separate item-by-item review listing the exact text of each of the 120 flaws. This revision therefore addresses the supplied grouped issue descriptions and creates explicit traceability for the revised requirements. It does not claim that a missing, itemized F-01–F-120 review has been individually reconciled.

No existing software repository, trained model, deployment configuration, measured benchmark, or API-provider contract was supplied. Accordingly, implementation status and performance results remain unverified. All requirements in this document are Proposed until approved by the project owner.

Contents

- 1. Introduction
- 2. Overall Description
- 3. Specific Requirements
- 4. Non-Functional Requirements
- 5. System Architecture and Data Requirements
- 6. External Interface Requirements
- 7. Verification and Acceptance Criteria
- 8. Assumptions, Dependencies, and Risks
- 9. Decision Register
- 10. MVP Prioritization and Roadmap
- Appendix A — Traceability Matrix
- Appendix B — Acceptance Test Suite
- Appendix C — ML Evaluation Protocol
- Appendix D — Hackathon Demo and Submission Checklist

- Appendix E — Glossary

1. INTRODUCTION

1.1 Purpose

This SRS specifies the intended behavior, quality attributes, interfaces, data handling, architecture boundaries, and verification criteria for the Intelligent Phishing and Scam Detection Platform. It is the proposed requirements baseline for implementation, testing, stakeholder review, and the hackathon demonstration.

1.2 Scope

The platform accepts user-submitted email text, SMS/chat text, URLs, and QR-code images. It extracts observable indicators, optionally consults a configured reputation provider, optionally uses a validated ML classifier, assigns a normalized risk score and risk band, and explains the evidence and limitations.

The MVP is an advisory tool. It does not prove maliciousness or safety, and it must not automatically visit, execute, download from, or submit information to analyzed destinations.

1.2.1 In scope

- Email and SMS text analysis with optional sender/subject metadata.
- URL parsing and local structural heuristics, including Unicode/punycode and lookalike indicators where implementable.
- QR image decoding and analysis of decoded URL/text payloads.
- Evidence-linked explanations, risk bands, uncertainty states, and safe next-step guidance.
- Optional reputation adapter and optional ML classifier, each independently disableable.
- Controlled test data, reproducible evaluation, and basic audit/health logging.
- Optional account/history functionality only if explicitly selected for the MVP.

1.2.2 Out of scope

- Guaranteeing that content is safe or malicious.
- Automatically browsing or resolving submitted destinations in the MVP.
- Mailbox/SMS inbox access, browser extensions, mobile apps, automatic blocking/quarantine, and enterprise gateway integration.
- Generative-AI chatbot features that do not have a separately justified user need.
- Claims of accuracy, novelty, or production readiness without evidence.

1.3 Target Users

User	Goal	MVP access
Public/guest user	Check suspicious content before acting.	Submit supported input and view a result; rate-limited.
Project evaluator/demo user	Observe the end-to-end detection and explanation workflow.	Use prepared safe demo examples.
Administrator/operator	Configure service, rules, provider keys, and operational settings.	Restricted operational access; exact account design is a decision.

Analyst/reviewer (future/optional)	Review aggregate feedback and evaluation outcomes.	Not required for MVP.

1.4 Definitions and Abbreviations

Term	Meaning
Risk score	Normalized 0–100 indicator score; not a calibrated probability unless separately validated and explicitly labeled.
Risk band	Human-readable category mapped from the risk score.
Evidence strength	Description of the source and quality of an observed indicator; distinct from model confidence.
Confidence	Model-estimated certainty only when the model exposes a defined, validated confidence measure. Not a guarantee.
Inconclusive	Analysis cannot support a useful classification because evidence is missing, invalid, conflicting, or unavailable.
Degraded result	Result generated while an optional component/provider is unavailable.
IOC	Indicator of compromise or suspicious activity.
PII	Personally identifiable information.
RBAC	Role-based access control.
TLS	Transport Layer Security.
FPR/FNR	False-positive rate / false-negative rate.

1.5 Conventions and Priority

Priority is represented as Must, Should, Could, or Future. Must requirements are necessary for MVP acceptance. Should requirements are important but may be deferred with an explicit waiver. Could requirements are optional enhancements. Future requirements are outside the MVP baseline. “Shall” is used for mandatory behavior within the stated scope; “should” is a recommendation; “may” is permissive. Every requirement is Proposed and has a test reference unless stated otherwise.

1.6 References

- IEEE Std 830-1998, Recommended Practice for Software Requirements Specifications (legacy structure).
- OWASP Application Security Verification Standard (ASVS), selected controls to be mapped during security review.
- OWASP Top 10, as a general risk reference.
- WCAG 2.2 Level AA, as the target accessibility standard.
- Documentation, license, and provenance statements for datasets and third-party libraries selected by the project.

2. OVERALL DESCRIPTION

2.1 Product Perspective

The intended MVP is a standalone web application. For the hackathon, the recommended implementation is one Python web service with clearly separated modules for input validation, text analysis, URL analysis, QR decoding, scoring, optional integrations, and presentation. This avoids premature microservice complexity. Production scaling may later separate these modules.

2.2 Product Functions

- Accept and validate supported submissions.
- Normalize URLs and decode QR payloads without opening destinations.
- Extract rule-based indicators from message content and URL structure.
- Optionally query a reputation provider under explicit privacy and quota controls.
- Optionally run a versioned ML model with a documented preprocessing pipeline.
- Aggregate evidence without double-counting correlated indicators.
- Return score, band, findings, evidence source, limitations, and safety guidance.
- Record minimized operational logs and optional analysis metadata.
- Support repeatable evaluation on documented datasets.

2.3 Operating Environment

Area	MVP recommendation	Status
Language	Python 3.11+; confirm dependency compatibility.	Proposed
Web framework	FastAPI recommended for typed API contracts; Flask is acceptable if already implemented.	Decision required
Analysis	Python standard URL parsing, regular expressions, Pandas; Scikit-learn only if model is selected.	Proposed
QR decoding	Maintained QR decoder with pinned version; PNG/JPEG initially.	Proposed
Database	SQLite for single-user local demo; PostgreSQL if multi-user hosted service is required.	Decision required
Deployment	Local demonstration or controlled HTTPS-hosted service; no deployment is claimed.	Decision required
Browser	Current stable Chrome, Edge, Firefox, Safari; responsive layout.	Proposed

2.4 Constraints

- The MVP shall not issue network requests to the destination being analyzed.
- External reputation providers are optional and must not be required for baseline analysis.
- All user input, uploaded images, decoded QR payloads, and provider responses are untrusted.

- No raw input retention by default; any retention must have a stated purpose and expiry.
- Model use is conditional on documented data provenance and evaluation.
- Secrets shall not be committed to source control or written to ordinary logs.

2.5 Assumptions and Dependencies

- Users submit content they are authorized to analyze.
- The project will use lawful, licensed, documented datasets.
- Risk thresholds and latency targets are proposals until approved.
- Provider terms, quotas, privacy practices, and uptime must be checked before activation.
- The MVP is decision support, not automatic enforcement.

3. SPECIFIC REQUIREMENTS

Each requirement below includes a stable ID, priority, status, rationale, and verification reference. Status remains Proposed until evidence is reviewed. Existing Version 1.0 identifiers are retained where possible.

3.1 User Interface and Input Validation

FR-UI-001 | Must | Proposed
The system shall present clearly labeled Email, SMS/Message, URL, and QR Image input modes.

Rationale: Prevents ambiguous submissions. Verification: AT-01

FR-UI-002 | Must | Proposed
The system shall validate required fields, input length, image type, image size, and request schema before analysis.

Rationale: Bounds untrusted input. Verification: AT-01, AT-02, AT-08

FR-UI-003 | Must | Proposed
The system shall display a safe validation message for empty, malformed, unsupported, or oversized input and shall not expose stack traces.

Rationale: Supports safe recovery. Verification: AT-01, AT-08

FR-UI-004 | Must | Proposed
The system shall treat submitted text, URLs, filenames, image bytes, and external provider responses as untrusted data.

Rationale: Reduces injection and parser risk. Verification: AT-09, AT-10

FR-UI-005 | Must | Proposed
The result screen shall state that the result is an estimate and that a low score does not guarantee safety.

Rationale: Prevents overconfidence. Verification: AT-14

FR-UI-006 | Must | Proposed
The system shall not automatically open, navigate to, resolve, execute, or download content from a submitted destination.

Rationale: Safe-by-default boundary. Verification: AT-04, AT-07

FR-UI-007 | Must | Proposed
The interface shall distinguish a completed analysis from an inconclusive or degraded analysis.

Rationale: Prevents missing evidence from appearing benign. Verification: AT-06, AT-11

3.2 Email Phishing Detection

FR-EMAIL-001 | Must | Proposed
The system shall accept email body text and optionally accept sender address, display name, subject, and reply-to address.

Rationale: Supports email analysis without requiring unavailable metadata. Verification: AT-02

FR-EMAIL-002 | Must | Proposed
The system shall identify configured indicators such as urgency, threats, credential requests, payment requests, impersonation cues, and mismatched supplied sender fields.

Rationale: Provides observable findings. Verification: AT-02, AT-03

FR-EMAIL-003 | Must | Proposed
Each major email finding shall identify an indicator category, severity, supporting evidence or safe excerpt, and plain-language explanation.

Rationale: Makes findings explainable. Verification: AT-02

FR-EMAIL-004 | Must | Proposed
Missing sender metadata shall be represented as unavailable and shall not alone be treated as proof of phishing.

Rationale: Avoids false inference. Verification: AT-02

FR-EMAIL-005 | Must | Proposed
The system shall analyze a valid message body when optional metadata is absent.

Rationale: Supports partial input. Verification: AT-02

FR-EMAIL-006 | Should | Proposed
The system should identify configured brand names and compare supplied sender/domain text with approved reference patterns; similarity alone shall not prove maliciousness.

Rationale: Adds explainable impersonation detection. Verification: AT-03

3.3 SMS and Message Scam Detection

FR-SMS-001 | Must | Proposed
The system shall accept SMS/chat text and an optional sender identifier.

Rationale: Supports message checks. Verification: AT-02

FR-SMS-002 | Must | Proposed
The system shall detect configured indicators such as OTP/password requests, urgent payments, delivery fees, prize claims, and requests to contact unverified numbers.

Rationale: Targets common scam patterns. Verification: AT-02

FR-SMS-003 | Must | Proposed
The system shall extract all candidate URLs up to a configurable maximum and analyze each through the URL pipeline.

Rationale: Avoids overlooking additional links. Verification: AT-04

FR-SMS-004 | Must | Proposed
The system shall recommend independent verification through an official channel when a message asks for credentials, payment, or urgent action.

Rationale: Provides actionable safety guidance. Verification: AT-02

3.4 URL Analysis and Reputation

FR-URL-001 | Must | Proposed
The system shall parse and normalize supported HTTP/HTTPS URLs using a standard URL parser and shall reject unsupported schemes for destination analysis.

Rationale: Creates consistent feature extraction. Verification: AT-04, AT-05

FR-URL-002 | Must | Proposed
The system shall inspect available URL features including hostname, subdomain depth, unusual port, IP-literal host, user-info, URL length, encoded characters, suspicious tokens, and punycode/Unicode indicators.

Rationale: Detects structural signals without visiting the site. Verification: AT-04, AT-05

FR-URL-003 | Must | Proposed
The system shall report HTTP as lacking transport encryption but shall not treat HTTP alone as proof of maliciousness.

Rationale: Keeps evidence proportional. Verification: AT-04

FR-URL-004 | Could | Proposed
The system may query a configured reputation provider through an adapter with a defined timeout, quota policy, response schema, and data-sharing notice.

Rationale: Adds external context without hard dependency. Verification: AT-11

FR-URL-005 | Must | Proposed
The system shall label reputation as unavailable, stale, invalid, or not configured when no usable current verdict is returned; none of these states shall count as benign evidence.

Rationale: Prevents false-safe results. Verification: AT-06, AT-11

FR-URL-006 | Must | Proposed
The MVP shall not make a live HTTP request to the submitted destination.

Rationale: Prevents SSRF and unintended interaction. Verification: AT-04, AT-07

FR-URL-007 | Must | Proposed
The system shall not automatically expand shortened URLs; it may flag shortener use and shall explain that the final destination was not inspected.

Rationale: Preserves safe behavior. Verification: AT-04

FR-URL-008 | Must | Proposed
The system shall render normalized URL and hostname as escaped, non-auto-navigating text.

Rationale: Prevents unsafe UI navigation. Verification: AT-09

FR-URL-009 | Must | Proposed
The system shall identify multiple URLs separately and associate each finding with the relevant URL or message segment.

Rationale: Improves traceability of evidence. Verification: AT-04

FR-URL-010 | Should | Proposed
The system should compare hostname labels against a configured list of trusted brands/domains and report lookalike or misleading-subdomain signals with the matched comparison basis.

Rationale: Adds explainable brand impersonation analysis. Verification: AT-05

FR-URL-011 | Must | Proposed
The system shall return a validation error for malformed or unsupported URL inputs and shall not silently repair them into a different destination.

Rationale: Prevents ambiguous interpretation. Verification: AT-05

3.5 QR-Code Verification

FR-QR-001 | Must | Proposed
The system shall accept configured raster QR images, initially PNG and JPEG, subject to size limits.

Rationale: Defines the supported upload boundary. Verification: AT-08

FR-QR-002 | Must | Proposed
The system shall validate actual file content as well as extension and declared content type.

Rationale: Reduces disguised-file risk. Verification: AT-08

FR-QR-003 | Must | Proposed
The system shall decode the QR payload and pass URL payloads to the URL pipeline without opening them.

Rationale: Enables safe QR checking. Verification: AT-07

FR-QR-004 | Must | Proposed
The system shall display decoded payload text safely and shall not create an automatically navigable link.

Rationale: Avoids accidental navigation. Verification: AT-07, AT-09

FR-QR-005 | Must | Proposed
The system shall distinguish no QR detected, decode failure, non-URL payload, and valid URL payload.

Rationale: Makes QR outcomes unambiguous. Verification: AT-07, AT-08

FR-QR-006 | Must | Proposed
The system shall delete temporary uploaded files after processing unless an approved retention policy explicitly requires otherwise.

Rationale: Minimizes retained sensitive data. Verification: AT-08

FR-QR-007 | Must | Proposed
The QR decoder shall run with configured file-size, pixel-count, and processing-time limits; where feasible, parsing shall run in a restricted worker/process.

Rationale: Limits parser resource abuse. Verification: AT-08

3.6 Risk Scoring and Classification

FR-RISK-001 | Must | Proposed
The system shall produce a normalized risk score from 0 to 100 only when sufficient valid evidence exists to run the scoring procedure.

Rationale: Defines bounded score output. Verification: AT-12

FR-RISK-002 | Must | Proposed
Initial proposed bands are Low 0–29, Moderate 30–59, High 60–79, and Critical 80–100; the project owner shall approve thresholds after validation.

Rationale: Provides a testable initial mapping without claiming calibration. Verification: AT-12

FR-RISK-003 | Must | Proposed
The scoring engine shall document feature groups, per-group caps, aggregation, and any calibration procedure; correlated indicators from one underlying cause shall not be counted repeatedly as independent strong evidence.

Rationale: Reduces score inflation. Verification: AT-12, AT-13

FR-RISK-004 | Must | Proposed
The system shall return a degraded result when an optional model or provider fails, provided local analysis can still run, and shall identify unavailable evidence sources.

Rationale: Maintains service continuity. Verification: AT-06, AT-11

FR-RISK-005 | Must | Proposed
The system shall state that low risk is not proof of safety and high risk is not conclusive proof of maliciousness.

Rationale: Communicates uncertainty. Verification: AT-14

FR-RISK-006 | Must | Proposed
Each result shall record the active rule-set version and model version, if a model was used.

Rationale: Supports reproducibility. Verification: AT-13

FR-RISK-007 | Must | Proposed
The displayed score shall be labeled as a normalized risk score, not as a probability of maliciousness, unless a probability calibration procedure is documented and validated.

Rationale: Avoids misleading numeric interpretation. Verification: AT-12

FR-RISK-008 | Must | Proposed
The system shall use an Inconclusive state when input is unsupported or usable evidence is insufficient; it shall not map missing evidence to Low risk.

Rationale: Separates uncertainty from low risk. Verification: AT-06

FR-RISK-009 | Must | Proposed
Conflicting signals shall be shown separately in the evidence list; the aggregate result shall identify conflict or reduced confidence rather than hide the disagreement.

Rationale: Preserves contradictory evidence. Verification: AT-13

3.7 Explanation and Awareness Guidance

FR-EXP-001 | Must | Proposed
Every major finding shall include a stable indicator code, category, severity, evidence source, and concise explanation.

Rationale: Enables review and traceability. Verification: AT-02, AT-04

FR-EXP-002 | Must | Proposed
The system shall distinguish observed input features, heuristic warnings, ML interpretations, and third-party reputation results.

Rationale: Separates facts from inferences. Verification: AT-13

FR-EXP-003 | Must | Proposed
The system shall provide safety guidance linked to the detected indicators, including not entering credentials or paying through a suspicious link and independently verifying requests.

Rationale: Turns detection into useful action. Verification: AT-02

FR-EXP-004 | Must | Proposed
The system shall not fabricate provider results, sender verification, or supporting evidence.

Rationale: Protects result integrity. Verification: AT-11, AT-13

3.8 Feedback and History

FR-HIST-001 | Could | Proposed
If accounts/history are enabled, an authenticated user shall access only their own saved results.

Rationale: History is optional for the hackathon MVP. Verification: AT-15

FR-HIST-002 | Could | Proposed
If history is enabled, users shall be able to delete individual results and retained raw input, except data retained under a disclosed legal/audit obligation.

Rationale: Supports user control over stored data. Verification: AT-15

FR-HIST-003 | Could | Proposed
The system should accept optional feedback about result usefulness or suspected error.

Rationale: Enables quality review. Verification: AT-16

FR-HIST-004 | Must | Proposed
Feedback shall not become a training label automatically; a documented review/labeling process is required.

Rationale: Prevents unverified feedback contaminating training. Verification: AT-16

3.9 Administration, Audit, and Operations

FR-ADMIN-001 | Must | Proposed
Administrative functions shall require authenticated administrator authorization.

Rationale: Protects configuration. Verification: AT-15

FR-ADMIN-002 | Must | Proposed
Provider settings shall be changeable only by authorized administrators; secret values shall never be displayed or logged.

Rationale: Protects credentials. Verification: AT-10, AT-15

FR-ADMIN-003 | Must | Proposed
The system shall log security-relevant administrative actions, authentication events, provider failures, and model/rule changes using minimized structured records.

Rationale: Supports operational investigation. Verification: AT-10

FR-ADMIN-004 | Should | Proposed
The system shall validate a rule/threshold configuration before activation and preserve a rollback path to the last valid version.

Rationale: Reduces configuration errors. Verification: AT-13

FR-ADMIN-005 | Should | Proposed
The service should expose health status for the application, database, analysis pipeline, and configured providers without revealing secrets.

Rationale: Supports demo and operations. Verification: AT-17

3.10 Machine Learning (Conditional)

FR-ML-001 | Should | Proposed
If ML is enabled, the system shall load an approved, versioned model artifact with its matching preprocessing pipeline.

Rationale: Makes model use reproducible. Verification: AT-18

FR-ML-002 | Must when ML enabled | Proposed
Inference preprocessing shall match the preprocessing used during training.

Rationale: Prevents train/serve skew. Verification: AT-18

FR-ML-003 | Must when ML enabled | Proposed
An enabled model shall be evaluated on held-out data using precision, recall, F1, confusion matrix, FPR, and FNR.

Rationale: Makes performance claims evidence-based. Verification: AT-19

FR-ML-004 | Must when ML enabled | Proposed
The system shall document dataset and evaluation coverage and shall not claim generalization beyond tested languages, domains, or attack types.

Rationale: States model limits. Verification: AT-19

FR-ML-005 | Must when ML enabled | Proposed
The ML component shall be disableable without disabling rule-based analysis.

Rationale: Provides safe fallback. Verification: AT-18

FR-ML-006 | Must when ML enabled | Proposed
Training and test partitions shall be checked for exact and near-duplicate leakage; where timestamps are available, a temporal holdout should be reported.

Rationale: Improves evaluation validity. Verification: AT-19

FR-ML-007 | Should | Proposed
Model changes shall be evaluated and versioned before activation; the previous approved model shall remain available for rollback.

Rationale: Supports safe updates. Verification: AT-18, AT-19

3.11 Error Handling and API Behavior

FR-ERR-001 | Must | Proposed
Processing failures shall return a safe error message and a correlation ID for troubleshooting.

Rationale: Enables safe support. Verification: AT-20

FR-ERR-002 | Must | Proposed
The API shall distinguish invalid input, unsupported type, rate limit, provider timeout, provider quota exhaustion, QR decode failure, unauthorized access, and internal failure.

Rationale: Makes failures actionable. Verification: AT-20

FR-ERR-003 | Must | Proposed
The system shall not expose stack traces, secrets, filesystem paths, SQL errors, or internal infrastructure details to users.

Rationale: Reduces information leakage. Verification: AT-10, AT-20

FR-ERR-004 | Must | Proposed
All request processing and external provider calls shall have configurable timeouts and a total request deadline.

Rationale: Bounds resource use. Verification: AT-11, AT-20

FR-API-001 | Must | Proposed
The API shall use a versioned route prefix, initially /api/v1, and validate requests against a documented schema.

Rationale: Stabilizes client contract. Verification: AT-21

FR-API-002 | Must | Proposed
A successful analysis response shall include request_id, input_type, analysis_status, risk_score or null, risk_band or Inconclusive, findings, evidence_sources, limitations, recommendations, rule_version, and model_version or null.

Rationale: Standardizes output. Verification: AT-21

FR-API-003 | Must | Proposed
The API shall use documented HTTP status codes: 200 for completed or degraded analysis, 400 for invalid request, 413 for oversized upload, 415 for unsupported media, 429 for rate limit, 401/403 for authentication/authorization, and 500/503 for internal or unavailable service conditions as appropriate.

Rationale: Makes client behavior predictable. Verification: AT-20, AT-21

FR-API-004 | Must | Proposed
The API shall return machine-readable error objects containing code, message, correlation_id, and retryable boolean; it shall omit sensitive internals.

Rationale: Supports client error handling. Verification: AT-20

3.12 Innovation and Differentiation

FR-INNOV-001 | Must | Proposed
The result screen shall link each major risk explanation to specific observed evidence and identify the evidence source type.

Rationale: Differentiation is testable through evidence traceability, not unsupported novelty claims. Verification: AT-02, AT-04

FR-INNOV-002 | Could | Proposed
The system should provide a small aggregate dashboard of counts by risk band and indicator category only if raw input is excluded and privacy thresholds are defined.

Rationale: Supports privacy-preserving awareness analytics. Verification: AT-22

4. NON-FUNCTIONAL REQUIREMENTS

The following values are proposed targets, not measured results. They require approval and must be measured under a documented test environment.

4.1 Performance and Capacity

NFR-PERF-001 | Should | Proposed
For text/URL requests with external lookups disabled, p95 end-to-end response time shall be at most 2 seconds in the approved baseline environment.

Rationale: Provides a measurable local-analysis target. Verification: PT-01

NFR-PERF-002 | Should | Proposed
For QR images within the approved size limit, p95 analysis time shall be at most 4 seconds with external lookups disabled.

Rationale: Bounds image workflow latency. Verification: PT-02

NFR-PERF-003 | Should | Proposed
Each external provider call shall time out after 3 seconds by default and total analysis shall have an 8-second deadline; values are subject to approval.

Rationale: Prevents stalled requests. Verification: AT-11, PT-03

NFR-PERF-004 | Could | Proposed
The proposed hosted target is 50 concurrent analysis requests without data leakage or unhandled server errors; this target must be load-tested before claiming support.

Rationale: Defines a future capacity target. Verification: PT-03

NFR-PERF-005 | Must | Proposed
The service shall enforce configurable request-size, rate, and processing-time limits.

Rationale: Protects availability. Verification: AT-08, PT-03

4.2 Security and Privacy

NFR-SEC-001 | Must for hosted deployment | Proposed
Production client-server traffic shall use HTTPS with TLS 1.2 or later.

Rationale: Protects data in transit. Verification: ST-01

NFR-SEC-002 | Must if authentication enabled | Proposed
If password authentication is implemented, passwords shall use Argon2id or bcrypt and shall never be stored in plaintext.

Rationale: Protects credentials. Verification: ST-02

NFR-SEC-003 | Must if protected features enabled | Proposed
Protected resources and admin operations shall enforce server-side authorization.

Rationale: Prevents unauthorized access. Verification: AT-15, ST-03

NFR-SEC-004 | Must | Proposed
The application shall test and mitigate injection, XSS, CSRF where applicable, insecure direct object references, and unsafe uploads.

Rationale: Covers common web risks. Verification: ST-04, ST-05

NFR-SEC-005 | Must | Proposed
Secrets shall be supplied via environment or managed secret storage and shall not be committed to source control.

Rationale: Protects provider and app secrets. Verification: ST-06

NFR-SEC-006 | Must | Proposed
Raw submissions shall not be persisted by default; the privacy notice shall disclose every enabled retention and external sharing purpose.

Rationale: Data minimization. Verification: AT-10, ST-07

NFR-SEC-007 | Must | Proposed
Logs shall redact credentials, tokens, and raw message content unless a specific, approved diagnostic need and retention rule exist.

Rationale: Limits log exposure. Verification: AT-10, ST-07

NFR-SEC-008 | Must | Proposed
External lookups shall transmit only the minimum necessary indicator and shall be disabled unless explicitly configured.

Rationale: Controls third-party data sharing. Verification: AT-11

NFR-SEC-009 | Must for production | Proposed
Retention periods for results, audit events, and backups shall be defined before production release; expired data shall be deleted by a documented process.

Rationale: Controls data lifecycle. Verification: ST-07

NFR-SEC-010 | Must for hosted deployment | Proposed
The deployment shall provide a privacy notice and identify applicable data-subject rights for its jurisdiction.

Rationale: Supports transparency. Verification: Review

NFR-SEC-011 | Future | Proposed
If destination resolution is introduced in a future release, it shall be isolated behind a dedicated SSRF defense design with private/loopback/link-local address blocking, redirect revalidation, DNS rebinding controls, and egress restrictions; it remains disabled in the MVP.

Rationale: Documents future boundary. Verification: Security design review

NFR-SEC-012 | Must | Proposed
Dependencies and model artifacts shall be version-pinned and obtained from controlled sources; integrity checks shall be used where supported.

Rationale: Reduces supply-chain risk. Verification: ST-08

NFR-SEC-013 | Should | Proposed
The project shall document an incident response process for leaked secrets, exposed data, compromised dependencies, and unsafe model/rule releases.

Rationale: Supports recovery. Verification: Review

4.3 Reliability and Availability

NFR-REL-001 | Future | Proposed
A production service may target 99.5% monthly availability only after monitoring and hosting are selected; this is not an MVP claim.

Rationale: Separates target from measured uptime. Verification: PT-03

NFR-REL-002 | Must | Proposed
Failure of an optional provider shall not prevent local analysis when local analysis remains available.

Rationale: Graceful degradation. Verification: AT-11

NFR-REL-003 | Must | Proposed
Retries shall be bounded and used only for safe operations; provider failures shall not trigger unbounded retry loops.

Rationale: Avoids retry storms. Verification: AT-11

NFR-REL-004 | Future | Proposed
Production deployments shall document backup frequency, backup expiry, restore procedure, and a tested restore objective.

Rationale: Defines recovery. Verification: Ops review

NFR-REL-005 | Must | Proposed
Failed or incomplete analysis shall never be displayed as a clean/low-risk result by default.

Rationale: Preserves uncertainty. Verification: AT-06

4.4 Usability and Accessibility

NFR-USE-001 | Must | Proposed
All input modes shall use consistent labels, validation messages, risk bands, and result terminology.

Rationale: Reduces user confusion. Verification: UT-01

NFR-USE-002 | Must | Proposed
Risk shall not be communicated by color alone; text labels and accessible names shall accompany visual indicators.

Rationale: Supports accessibility. Verification: UT-01

NFR-USE-003 | Should | Proposed
The UI should target WCAG 2.2 AA, including keyboard operation, visible focus, labels, sufficient contrast, and programmatic error messages.

Rationale: Provides an actionable accessibility target. Verification: UT-02

NFR-USE-004 | Should | Proposed
A first-time guest user should complete a supported analysis and find the score, evidence, and next step without creating an account.

Rationale: Supports hackathon usability. Verification: UT-01

NFR-USE-005 | Must | Proposed
The interface shall remain usable at 360 px mobile width and common desktop widths without horizontal page overflow for core flows.

Rationale: Responsive behavior is measurable. Verification: UT-03

4.5 Maintainability and Portability

NFR-MNT-001 | Must | Proposed
Input handling, analyzers, scoring, provider adapters, persistence, and presentation shall be separate testable modules.

Rationale: Supports maintainable implementation. Verification: Code review

NFR-MNT-002 | Must | Proposed
The project shall include pinned dependencies and reproducible installation/run instructions.

Rationale: Supports reproducible demo. Verification: Build check

NFR-MNT-003 | Should | Proposed
Risk thresholds and rules shall be configuration-driven and versioned.

Rationale: Allows controlled tuning. Verification: AT-13

NFR-MNT-004 | Must | Proposed
Logs shall be structured with timestamp, severity, event type, and correlation ID, without unnecessary raw inputs.

Rationale: Supports debugging with privacy. Verification: AT-10

NFR-MNT-005 | Must | Proposed
Automated tests shall cover parsing, scoring boundaries, authorization where enabled, QR handling, and error paths.

Rationale: Provides regression protection. Verification: Test suite

4.6 ML Quality

NFR-ML-001 | Must when ML enabled | Proposed
Before enabling ML, the team shall set minimum precision/recall criteria and document the rationale based on intended use and validation data.

Rationale: Avoids arbitrary acceptance. Verification: AT-19

NFR-ML-002 | Must when ML enabled | Proposed
Evaluation shall report FPR and FNR separately, as well as precision, recall, F1, confusion matrix, and dataset composition.

Rationale: Makes error tradeoffs visible. Verification: AT-19

NFR-ML-003 | Must when ML enabled | Proposed
Dataset splitting shall prevent exact and near-duplicate leakage; a time-based holdout should be used where timestamps are available.

Rationale: Improves validity. Verification: AT-19

NFR-ML-004 | Should when ML enabled | Proposed
Known language, region, domain-age, and attack-type gaps shall be documented where data permits.

Rationale: Limits overgeneralization. Verification: AT-19

NFR-ML-005 | Must when ML enabled | Proposed
Every model or threshold update shall be versioned, evaluated, and rollback-capable.

Rationale: Supports safe model lifecycle. Verification: AT-18, AT-19

5. SYSTEM ARCHITECTURE AND DATA REQUIREMENTS

5.1 Proposed MVP Architecture

Component	Responsibility	Boundary / safeguard
Web UI	Collect supported input and display result.	Escaped text; no auto-open links.
API controller	Validate schema, apply rate limits, assign request ID, orchestrate analysis.	Versioned /api/v1; safe errors.
Normalizer	Normalize text/URL and extract candidate URLs.	Do not silently change destination meaning.

Message analyzer	Apply message indicators and optional brand context.	Evidence-linked findings.
URL analyzer	Parse URL and compute structural indicators.	No destination network requests.
QR decoder	Decode image payload.	Size/pixel/time limits; temporary cleanup.
Scoring engine	Group, cap, and aggregate signals; decide Low/Moderate/High/Critical/Inconclusive .	Versioned method; no false-safe missing data.
Optional ML adapter	Load model and matching preprocessing.	Disable independently; record version.
Optional reputation adapter	Query approved provider.	Explicit opt-in, timeout, quota, minimal data.
Persistence/audit	Store only approved metadata and operational events.	No raw content by default; role restrictions.

5.2 Data Entities

Entity	Core fields (proposed)	Notes
users (optional)	id, email, password_hash, role, status, created_at	Only if accounts are approved.
analysis_requests	id, user_id nullable, input_type, input_fingerprint nullable, submitted_at, status, correlation_id	Avoid raw content.
analysis_results	id, request_id, score nullable, risk_band, analysis_status, rule_version, model_version nullable, completed_at	Score may be null when inconclusive.
analysis_findings	id, result_id, indicator_code, category, severity, evidence_source_type, evidence_excerpt nullable, explanation	Minimize evidence excerpts.
provider_checks	id, result_id, provider, queried_at, status, verdict nullable, freshness_state	Unknown is not benign.
feedback (optional)	id, result_id, feedback_type, comment nullable, review_status, created_at	Feedback not auto-label.
rule_versions	id, version, configuration_hash, active, approved_by, created_at	Preserve rollback.
model_registry (optional)	id, model_version, artifact_hash, preprocessing_version, evaluation_report, approval_status	Only for ML deployment.
audit_events	id, actor_id nullable, event_type, target_id nullable, timestamp, correlation_id, outcome	Minimize content and protect integrity.

provider_config	provider, enabled, timeout_ms, secret_reference, updated_by, updated_at	Store secret reference, not secret value.

5.3 Data Retention and Privacy

Default behavior: process submitted content in memory and do not store raw email/SMS text, full URLs, or QR payloads. Persist only operational metadata required for the response unless the user-facing product explicitly enables history after approval. If raw input retention is approved, document purpose, access roles, encryption, expiry, deletion, backup expiry, and external disclosure before activation.

5.4 Workflow

- 1. User selects an input type and submits text, URL, or QR image.
- 2. API validates size, schema, type, and request limits.
- 3. Normalizer extracts candidate URLs; QR decoder extracts payload without navigation.
- 4. Local analyzers generate structured findings with evidence and source type.
- 5. Optional ML and reputation adapters run only if enabled and within deadline.
- 6. Scoring engine groups correlated indicators, caps group contributions, handles conflicts/missing sources, and returns score or Inconclusive.
- 7. UI shows risk band, evidence, source status, limitations, and safety advice.
- 8. The service writes minimized audit metadata; optional history follows approved retention policy.

5.5 Risk Scoring Specification

The 0–100 value is a normalized risk score, not a probability of maliciousness. A proposed scoring method groups signals into independent families (message language, URL structure/identity, reputation, and optional ML). Each family contributes a bounded value; repeated indicators from the same root cause are deduplicated or capped. The final score is computed from the documented family contributions and normalized to 0–100. Exact weights are [STAKEHOLDER DECISION REQUIRED] and must be calibrated on a validation set before the thresholds are treated as approved.

Evidence state	Required behavior
Valid positive risk evidence	Increase the relevant family contribution within its cap; show the supporting indicator.
Missing evidence	No positive or negative contribution; mark source unavailable/not supplied.
Stale reputation	Show stale state; do not count as a current benign verdict.
Provider unavailable/quota exceeded	Continue local analysis; return degraded status and show provider failure.
Conflicting evidence	Show both sides and set a conflict/limited-evidence flag; do not hide the conflict.
Insufficient usable evidence	Return Inconclusive; do not assign Low simply because no rule fired.

ML disabled/unavailable	Use remaining local rules; indicate ML was not used.	
Low score	State that it does not guarantee safety.	
Proposed score	**Band**	**Interpretation**
0–29	Low	Few configured indicators observed; not a safety guarantee.
30–59	Moderate	Some warnings; independently verify before acting.
60–79	High	Strong or multiple warnings; avoid interaction pending verification.
80–100	Critical	Very strong configured warnings; do not provide credentials/payment.
No usable score	Inconclusive	Evidence is insufficient or invalid to support a score.

5.6 Architecture Diagram (text form)

Browser UI → /api/v1/analyze → Input validation → Normalization/QR decoding → Message and URL analyzers → [Optional ML adapter] + [Optional reputation adapter] → Deduplicate/group signals → Risk and uncertainty engine → Result/explanation response → UI. The destination URL itself is never fetched by the MVP.

5.7 Future Production Architecture

A production deployment may add a managed database, isolated QR parsing worker, centralized monitoring, secret manager, model registry, backup/restore automation, and controlled reputation-provider integration. These are future architecture options, not claims about the current implementation.

6. EXTERNAL INTERFACE REQUIREMENTS

6.1 API Contract

Base path: /api/v1. Content types: application/json for text/URL requests and multipart/form-data for QR uploads. Authentication is not required for guest analysis unless abuse risk or deployment policy requires it; any enabled account/history/admin routes must be authenticated and authorized.

6.1.1 Example request

POST /api/v1/analyze JSON: {"type":"url","content":"https://example.invalid/path"}

6.1.2 Example response schema (illustrative)

{"request_id":"opaque-id","input_type":"url","analysis_status":"completed","risk_score":42,"risk_band":"Moderate","findings":[{"indicator_code":"URL_HTTPS_MISSING","severity":"low","evidence_source_type":"heuristic","explanation":"The URL uses HTTP, so transport encryption is not indicated."}],"evidence_sources":{"rules":"rules-v1","ml":null,"reputation":"not_configured"},"limitations":["Th

e destination was not visited."],"recommendations":["Verify the domain through an official channel."],"rule_version":"rules-v1","model_version":null}

Example values are illustrative, not test results. A response may use risk_score=null and risk_band='Inconclusive' when usable evidence is insufficient.

6.1.3 Error schema

{"error":{"code":"INVALID_URL","message":"Enter a valid HTTP or HTTPS URL.","correlation_id":"opaque-id","retryable":false}}

HTTP status	Use
200	Completed or degraded analysis with explicit analysis_status.
400	Invalid request or malformed content.
401 / 403	Authentication required / operation not authorized.
413	Upload or request exceeds configured size limit.
415	Unsupported media type.
429	Rate limit exceeded.
500	Unexpected internal error with safe message.
503	Required service unavailable; use only when no valid degraded response can be produced.

6.2 External Reputation Provider

Provider use is optional. Before activation, record provider name, API contract, quota, timeout, freshness definition, cache permission, data transmitted, retention terms, and fallback behavior. Send the minimum required URL/domain indicator; do not send full message text unless explicitly approved and necessary. Provider response content is untrusted and must be schema-validated.

6.3 User Interface and Accessibility

- Risk band shall be displayed as text as well as visual styling.
- Findings shall be grouped by category and include evidence, explanation, and source type.
- Submitted URLs shall not be auto-linked.
- Errors shall be announced programmatically and associated with relevant inputs.
- Core flows shall be keyboard-operable with visible focus and accessible labels.

7. VERIFICATION AND ACCEPTANCE CRITERIA

7.1 General Verification Rules

Verification methods: test (T), inspection (I), analysis (A), or demonstration (D). Test data shall be controlled and must not include live malicious payload execution. Every Must requirement must map to at least one test or documented inspection. Requirements without a test mapping are release blockers until a test is assigned.

7.2 Release Exit Criteria

- All Must requirements have passed or have a written waiver approved by the project owner.
- No unresolved Critical/High security defect remains in the release candidate.
- Core workflows for email, SMS, URL, and QR have repeatable demonstration examples.
- Risk-score boundaries, Inconclusive state, provider failure, and disabled-ML fallback are tested.
- No destination URL is automatically visited by the application.
- The result UI communicates uncertainty and evidence source.
- Setup instructions and demo fallback plan are tested on a clean environment.
- No accuracy, availability, or latency claim is published without a recorded measurement.

7.3 Defect Severity

Severity	Definition	Release rule
Critical	Data exposure, arbitrary destination access/SSRF, remote code execution, auth bypass, or app cannot start.	Release blocker.
High	Core analysis wrong for common supported input, unsafe QR behavior, or major privacy/security failure.	Release blocker unless owner-approved mitigation.
Medium	Feature degradation with workaround; limited result display or noncritical flow failure.	May release with documented workaround.
Low	Cosmetic issue or minor wording defect without safety impact.	May defer.

7.4 Performance Test Protocol

Record machine/CPU/RAM, OS, Python/dependency versions, dataset, request payload sizes, concurrency, warm-up count, number of measured requests, p50/p95/p99, errors, and whether provider calls were enabled. Do not state that a target passed without retaining the run results. Proposed targets remain unapproved until stakeholder sign-off.

8. ASSUMPTIONS, DEPENDENCIES, AND RISKS

Risk	Impact	Mitigation / verification
Dataset bias or incorrect labels	Misleading model output.	Document provenance, label process, class balance, duplicates, and test split; AT-19.
New attack patterns	False negatives.	Document limitations, version rules, collect reviewed feedback; AT-19.
Provider outage/quota	Reduced evidence.	Timeout, graceful degradation, explicit status; AT-11.
External data disclosure	Privacy risk.	Provider opt-in, minimum data, privacy notice; ST-07.

False positives	Legitimate content warned on.	Show evidence, tune thresholds, collect reviewed feedback.
False negatives	Malicious content appears low risk.	Prominent limitations, evaluate recall, no safety guarantee.
Malformed or hostile QR image	Parser crash/resource exhaustion.	Size/pixel/time limits, dependency patching, isolation; AT-08.
Overconfidence in score	Unsafe user decision.	Use normalized score label, Inconclusive state, evidence-based guidance; AT-14.
Scope expansion	MVP not completed.	Prioritize Must list and require approval for additions.
Unverified target metrics	Unsupported project claims.	Keep proposed vs measured values separate; performance protocol.

8.1 User Outcome Measures

Proposed measures for the demo are: percentage of seeded scenarios for which expected indicators appear; percentage of results with evidence-linked explanations; successful QR decoding rate on the controlled QR set; false-positive/false-negative counts on the held-out dataset; and median/p95 latency under a recorded environment. Targets are [STAKEHOLDER DECISION REQUIRED]; results must be measured rather than assumed.

8.2 Innovation Claims

The defensible project differentiator is the combination of multi-input analysis, evidence-linked explanations, safe QR handling, transparent uncertainty, and privacy-conscious fallback behavior. These are design goals, not claims of novelty or superior detection performance. Any competitive claim must be supported by comparison against a documented baseline.

9. DECISION REGISTER

ID / decision	Recommended option	Impact if unresolved	Owner	Due / status
D-01 Framework	Choose FastAPI for typed API unless an existing Flask implementation is already functional.	Affects API structure, testing, deployment.	Project lead	Before implementation freeze / Open
D-02 Database	SQLite for single-user demo; PostgreSQL only if hosted multi-user persistence is required.	Affects accounts, history, migrations, ops.	Project lead	Before persistence work / Open
D-03 Accounts/history	Disable for MVP unless required by judging criteria; keep guest analysis.	Avoids unnecessary auth/privacy scope.	Project owner	Before UI freeze / Open

D-04 Reputation provider	Start with provider disabled; choose one only after reviewing terms, quota, data sharing, and API contract.	External dependency and privacy impact.	Security/technical lead	Before integration / Open
D-05 ML model	Enable only if dataset provenance and held-out evaluation are ready; otherwise use rule-based baseline.	Affects model claims and scoring.	ML lead	Before model integration / Open
D-06 Risk weights	Calibrate with validation data and approve exact weights/thresholds.	Affects score behavior and acceptance tests.	ML/security lead	Before release candidate / Open
D-07 Supported languages	Set initial language support; do not imply multilingual detection without testing.	Affects dataset and message rules.	Product owner	Before demo content freeze / Open
D-08 Input limits/rate	Set text length, QR bytes/pixels, per-IP rate, and total timeout.	Affects safety and performance.	Technical lead	Before deployment / Open
D-09 Retention	Default to no raw input persistence; define logs/result retention if hosted.	Privacy and deletion duties.	Project owner	Before hosted release / Open
D-10 Performance targets	Approve or revise p95 and concurrency targets after selecting test hardware.	Avoids ungrounded performance claims.	Project owner/QA	Before benchmark / Open
D-11 Accessibility	Confirm WCAG 2.2 AA as a target and test scope.	Affects UI verification.	UI/QA lead	Before final demo / Open
D-12 Production hosting	Select host, HTTPS, backup, monitoring, and incident response only if production deployment is planned.	Operational requirements remain incomplete.	Project owner	Before production / Future
D-13 Itemized F-01–F-120 review	Provide the prior itemized review if each individual flaw must be audited one-to-one.	Current source gives grouped themes, not each flaw statement.	Reviewer/project owner	Before final audit sign-off / Open

10. MVP PRIORITIZATION AND ROADMAP

Priority tier	Scope	Dependencies / order
Must Have — Hackathon	Email/SMS text, URL structure analysis, QR decode, explainable rule findings, risk bands plus Inconclusive, safe UI, no destination visits, input limits, error	1. Input/API → 2. local analyzers → 3. evidence schema → 4. scoring/uncertainty → 5. UI → 6. tests.

	handling, controlled test suite, setup/demo guide.	
Should Have	Lookalike-domain hints, polished keyboard-accessible UI, provider adapter with provider disabled by default, ML model if evaluation is complete, health status.	After Must workflows and tests pass.
Could Have	Optional feedback, aggregate privacy-preserving counts, user history, one reputation provider.	Only if time and privacy decisions permit.
Future production	Accounts/RBAC at scale, PostgreSQL, managed secrets, monitoring, backups, model registry, isolated workers, incident response automation, SSRF-safe URL resolution if ever justified.	Requires architecture/security review; destination resolution remains excluded from MVP.

10.1 Implementation Order

- Phase 1: approve scope, language, input limits, risk labels, and data policy.
- Phase 2: define finding and API schemas; implement validation and correlation IDs.
- Phase 3: implement message, URL, and QR local analysis; ensure no URL fetch occurs.
- Phase 4: implement evidence grouping, score, Inconclusive/degraded states, and explanations.
- Phase 5: build UI and accessible result display.
- Phase 6: run acceptance/security tests and measure latency.
- Phase 7: add optional ML/reputation only after their decisions and tests are complete.
- Phase 8: rehearse demo, verify clean setup, and prepare fallback screenshots/video if the live environment fails.

APPENDIX A — REQUIREMENTS TRACEABILITY MATRIX

The matrix maps each requirement to its primary component and verification reference. “Inspection” means review of code/configuration/documentation; tests are listed in Appendix B. Any blank mapping would be a release blocker; the matrix below provides mappings for all requirements introduced in this revision.

Requirement IDs	Component	Verification reference	Coverage
FR-UI-001–007	UI / API validation	AT-01, AT-06, AT-09, AT-14	Mapped
FR-EMAIL-001–006	Message analyzer	AT-02, AT-03	Mapped
FR-SMS-001–004	Message analyzer / URL extractor	AT-02, AT-04	Mapped
FR-URL-001–011	URL analyzer / reputation adapter	AT-04, AT-05, AT-06, AT-11	Mapped
FR-QR-001–007	QR decoder / upload handler	AT-07, AT-08, AT-09	Mapped
FR-RISK-001–009	Scoring and uncertainty engine	AT-06, AT-12, AT-13, AT-14	Mapped
FR-EXP-001–004	Explanation/result renderer	AT-02, AT-04, AT-11, AT-13	Mapped

FR-HIST-001–004	Optional history/feedback modules	AT-15, AT-16	Conditional; only if enabled
FR-ADMIN-001–005	Admin/config/audit modules	AT-10, AT-15, AT-17	Mapped/conditional
FR-ML-001–007	Optional ML adapter and evaluation pipeline	AT-18, AT-19	Conditional; only if ML enabled
FR-ERR-001–004	API error middleware	AT-11, AT-20	Mapped
FR-API-001–004	API controller/schema	AT-20, AT-21	Mapped
FR-INNOV-001–002	Finding schema / aggregate dashboard	AT-02, AT-04, AT-22	AT-22 conditional
NFR-PERF-001–005	Service runtime / load test	PT-01–PT-03, AT-08	Targets proposed, not measured
NFR-SEC-001–013	Deployment/security controls	ST-01–ST-08, AT-10, AT-15	Mapped; future controls conditional
NFR-REL-001–005	Service operations / failure handling	AT-06, AT-11, PT-03	Availability/backup are future
NFR-USE-001–005	Frontend	UT-01–UT-03	Mapped
NFR-MNT-001–005	Codebase / CI / test suite	Inspection, build check, regression suite	Mapped
NFR-ML-001–005	ML evaluation/model lifecycle	AT-18, AT-19	Conditional; only if ML enabled

A.1 Original Version 1.0 Identifier Crosswalk

Original IDs	Revised handling
FR-UI-001–006	Retained and expanded as FR-UI-001–007.
FR-EMAIL-001–005	Retained; brand context added as FR-EMAIL-006.
FR-SMS-001–004	Retained; multi-URL behavior clarified.
FR-URL-001–008	Retained and expanded as FR-URL-001–011.
FR-QR-001–006	Retained and expanded as FR-QR-001–007.
FR-RISK-001–007	Retained and expanded as FR-RISK-001–009.
FR-EXP-001–005	Core explanation requirements retained; evidence/source distinctions consolidated into FR-EXP-001–004.
FR-HIST-001–004	Retained as conditional requirements; priorities corrected to reflect optional history.
FR-ADMIN-001–005	Retained; priority semantics clarified.
FR-ML-001–005	Retained as conditional on ML being enabled; expanded with data leakage and rollback controls.
FR-ERR-001–004	Retained; API contract requirements added.

NFR-PERF/SEC/REL/USE/MNT/ML	Retained and expanded; proposed targets explicitly separated from measured results.

APPENDIX B — ACCEPTANCE TEST SUITE

All tests use synthetic or appropriately licensed static samples. Do not execute malware, visit malicious destinations, or send test data to a live third party unless separately authorized. Pass/fail is determined by the expected outcome below.

Test ID	Requirement(s)	Scenario / input	Preconditions	Expected outcome	Pass criterion
AT-01	FR-UI-001, FR-UI-002, FR-UI-003	Submit empty text and missing required fields.	App running; no special setup.	400/validation state; no score; safe message.	Pass if validation is shown and no fabricated result is returned.
AT-02	FR-EMAIL-001–005, FR-SMS-001–004, FR-EXP-001–003	Use synthetic message containing urgency plus a request for credentials/payment.	Rules loaded.	Relevant indicator codes, evidence, explanation, score/band or Inconclusive, and safety advice.	Pass if every major finding is evidence-linked and no missing metadata is treated as proof.
AT-03	FR-EMAIL-006	Compare a synthetic sender/domain with a configured brand reference.	Reference list configured.	Similarity/mismatch signal is explained; similarity alone is not conclusive.	Pass if matched reference basis is displayed and no definitive malicious claim is made from similarity alone.
AT-04	FR-SMS-003, FR-URL-001–009, FR-URL-007	Submit message with two URLs including a shortener; use static strings only.	Destination network disabled in test environment.	Each URL is analyzed separately; shortener not expanded; no outbound request.	Pass if all candidate URLs are represented and network capture shows no destination visit.
AT-05	FR-URL-002, FR-URL-010, FR-URL-011	Test malformed URL, Unicode/punycode hostname, misleading subdomain, IP-literal, and unusual port.	Curated test cases available.	Valid URLs are normalized consistently; malformed input is rejected; indicators explain observed features.	Pass if expected parsing and findings match fixtures.
AT-06	FR-URL-005, FR-RISK-004, FR-RISK-008, NFR-REL-005	Disable reputation provider and submit an input with few local indicators.	Provider disabled.	Provider state is not configured/unavailable; score is not called proof of safety; Inconclusive used if evidence is insufficient.	Pass if missing provider data never adds benign evidence.

AT-07	FR-QR-003–005, FR-UI-006	Upload a valid QR image encoding a URL.	Static test image; network egress blocked.	Payload decoded and analyzed; no browser navigation or destination request.	Pass if decoded payload is shown safely and no outbound destination request occurs.
AT-08	FR-UI-002, FR-QR-001–002, FR-QR-006–007, NFR-PERF-005	Upload unsupported, oversized, corrupt, and high-pixel-count image files.	Upload test fixtures prepared.	Upload rejected or handled within limit; temporary files cleaned; no crash.	Pass if resource limits hold and cleanup is verified.
AT-09	FR-UI-004, FR-URL-008, FR-QR-004, NFR-SEC-004	Submit HTML/script-lookin g text and a QR payload containing markup.	Test environment.	Content is escaped as text; no script runs; URLs are not auto-linked.	Pass if browser execution does not occur.
AT-10	FR-ADMIN-002–0 03, FR-ERR-003, NFR-SEC-005–00 7, NFR-MNT-004	Trigger provider error using a fake secret-like token and inspect logs/config UI.	Test secret fixture only.	Secret not displayed/logged; logs contain correlation ID and redacted data.	Pass if no secret or unnecessary raw input appears.
AT-11	FR-URL-004–005, FR-RISK-004, FR-ERR-002/004, NFR-PERF-003, NFR-REL-002/003	Use a mocked provider that times out, returns malformed JSON, quota error, stale verdict, or conflict.	Mock provider configured.	Request respects deadline; local analysis completes where possible; status is explicit; no fabricated clean result.	Pass if each failure mode maps to documented status.
AT-12	FR-RISK-001–003 , FR-RISK-007, NFR-MNT-005	Unit test scores at 0, 29, 30, 59, 60, 79, 80, 100 and out-of-range values.	Scoring function isolated.	Boundaries map to defined bands; out-of-range contributions are capped/rejected; score labeled normalized.	Pass if every boundary matches specification.
AT-13	FR-RISK-003, FR-RISK-006, FR-RISK-009, FR-ADMIN-004, NFR-MNT-003	Use duplicate correlated indicators and conflicting evidence; change rule version.	Fixture rules and findings.	Correlated evidence capped/deduplicat ed; conflicts shown; version recorded; rollback available.	Pass if score does not double-count the same root cause and versions are traceable.
AT-14	FR-UI-005, FR-RISK-005, FR-RISK-008	Review Low, High, Critical, Degraded, and Inconclusive results.	Fixture results.	Text warns that score is not proof; Inconclusive is not Low; degraded sources are visible.	Pass if wording and state are present in every result layout.
AT-15	FR-HIST-001–002 , FR-ADMIN-001, NFR-SEC-003	If accounts/history enabled, attempt cross-user result access and	Two test users and non-admin role.	Access denied; event logged; no data disclosed.	Pass if server-side checks deny both attempts. Mark N/A if optional features disabled.

		unauthorized admin action.			
AT-16	FR-HIST-003–004	Submit feedback for a result.	Feedback enabled.	Feedback is stored as unverified feedback, not training label.	Pass if training data is unchanged until review.
AT-17	FR-ADMIN-005	Check health endpoints with database/provider unavailable.	Mock failure.	Health reports component status without exposing secrets.	Pass if status is accurate and safe.
AT-18	FR-ML-001–002, FR-ML-005, FR-ML-007, NFR-ML-005	Load matching model/preprocessor, then disable model or supply mismatched version.	ML enabled in test profile.	Version mismatch fails safely; model can be disabled; rules remain operational; rollback possible.	Pass if inference never uses incompatible preprocessing.
AT-19	FR-ML-003–004, FR-ML-006, NFR-ML-001–005	Run documented held-out evaluation and duplicate-leakage check.	Licensed labeled dataset and fixed split.	Report precision, recall, F1, confusion matrix, FPR, FNR, class counts, limitations, and versions.	Pass if report is reproducible; no metric is invented; acceptance thresholds were approved.
AT-20	FR-ERR-001–004, FR-API-003–004	Exercise invalid input, 413, 415, 429, auth failure, internal exception.	Test API deployment.	Correct status and machine-readable error; no stack trace; correlation ID included.	Pass if response schema and status mapping match API contract.
AT-21	FR-API-001–004	Contract test valid JSON, invalid schema, URL, QR multipart, degraded response.	API schema available.	Responses conform to versioned schema and required fields.	Pass if schema validation succeeds for valid responses and rejects invalid requests.
AT-22	FR-INNOV-002	Review aggregate dashboard with test dataset.	Feature enabled and minimum group size policy approved.	Only aggregate counts shown; no raw message/URL content exposed.	Pass if no individual submission is recoverable from the dashboard.
PT-01	NFR-PERF-001	Run at least 100 warm text/URL requests with provider disabled; record p50/p95/p99.	Fixed machine and dependency versions.	Report latency distribution and errors.	Pass only if approved p95 target is met and run log is retained.
PT-02	NFR-PERF-002	Run at least 50 QR requests across the approved image size range.	Fixed machine and fixture set.	Report latency distribution, decode failures, and resource use.	Pass only if approved target is met.
PT-03	NFR-PERF-003–005, NFR-REL-001	Run documented concurrency/load	Load tool and fixed environment.	Record concurrency, p95/p99, errors,	Pass only against an approved target; do not

		test with controlled provider mocks.		timeouts, memory, and recovery.	claim production uptime from this test.
ST-01	NFR-SEC-001	Inspect hosted transport and TLS configuration.	Hosted environment.	HTTPS and TLS 1.2+ used.	Pass if verified by configuration inspection and external TLS test.
ST-02	NFR-SEC-002	Inspect auth storage if passwords exist.	Auth enabled.	Adaptive hash only; no plaintext passwords.	Pass if schema and test records confirm.
ST-03	NFR-SEC-003	Attempt unauthorized access to protected endpoints.	Protected routes enabled.	401/403; no data leakage.	Pass if every route checks authorization server-side.
ST-04	NFR-SEC-004	Run safe injection/XSS/CSRF/IDOR test cases.	Isolated test deployment.	Payloads do not execute or bypass controls.	Pass if relevant tests are blocked/escaped.
ST-05	FR-QR-002, FR-QR-007, NFR-SEC-004	Upload mismatched extension/content type and malformed image.	Isolated test deployment.	Rejected safely; no uncontrolled resource use.	Pass if file validation and limits hold.
ST-06	NFR-SEC-005, NFR-SEC-012	Scan repository and runtime config for committed secrets and unpinned dependencies.	Repository snapshot.	No live secrets committed; critical dependencies pinned and sourced.	Pass if findings are resolved or documented.
ST-07	NFR-SEC-006–009	Inspect storage, logs, deletion, and backup retention settings.	Persistence configured.	Raw content absent by default; retention and deletion work as documented.	Pass if inspection and deletion test succeed.
ST-08	NFR-SEC-012	Verify dependency lock and model artifact hash/version.	Build artifacts available.	Build is reproducible and model artifact provenance is documented.	Pass if versions and hashes match approved records.
UT-01	NFR-USE-001–004	Ask representative testers to analyze one message and find the reason and next step.	At least 5 testers recommended for formative feedback.	Record task success, completion time, and confusion points; do not claim statistical generalization.	Pass criterion to be approved; report observed counts.
UT-02	NFR-USE-002–003	Keyboard-only and screen-reader review of core flow.	Supported browser/assistive technology.	Inputs, errors, focus, score, and findings are operable/readable.	Pass against documented WCAG checklist.

UT-03	NFR-USE-005	Check 360 px mobile and desktop viewports.	Browser dev tools or devices.	No core action hidden; no horizontal page overflow.	Pass if core workflow remains usable.

APPENDIX C — ML EVALUATION PROTOCOL

- Record dataset name, source, license, collection date, label definitions, language, and known limitations.
- Remove exact duplicates and assess near-duplicates before splitting; keep related variants in the same partition where possible.
- Create train/validation/test splits before model tuning. Use a temporal holdout if timestamps exist and document any limitation if they do not.
- Fit preprocessing only on training data; apply the fitted preprocessing unchanged to validation/test/inference.
- Compare against a simple rule-based baseline and a majority-class baseline where meaningful.
- Report confusion matrix, precision, recall, F1, FPR, FNR, sample counts, class balance, threshold, model version, and confidence intervals where feasible.
- Inspect errors by input type and available language/domain segments. Do not infer coverage for unrepresented segments.
- Do not choose thresholds solely to maximize accuracy; discuss the consequences of false positives and false negatives.
- Store evaluation report and artifact hash with model version. Roll back if the approved acceptance criteria are not met.
- Monitor future performance only if a lawful, privacy-preserving feedback/measurement mechanism exists; user feedback alone is not ground truth.

No ML model, metric, or threshold is asserted to be implemented or validated by this document.

APPENDIX D — HACKATHON DEMO AND SUBMISSION CHECKLIST

Area	Checklist item	Status
Demo dataset	Prepare synthetic emails, SMS, benign URLs, suspicious-looking URLs, malformed URLs, Unicode/punycode cases, and QR images; label expected indicators.	To do
Safety	Block outbound requests to submitted destinations during demo; demonstrate with network monitoring if possible.	To do
Workflow	Demonstrate message → URL → QR → explanation → safe advice.	To do
Uncertainty	Show provider disabled, degraded response, and Inconclusive state.	To do
Reproducibility	Run setup from a clean environment using pinned dependencies.	To do

Evidence	Capture test logs and measured latency only after running tests.	To do
Fallback	Prepare local sample data and screenshots/video in case hosted network/provider fails.	To do
Privacy	Verify no raw submissions or secrets appear in logs or screenshots.	To do
Presentation	Explain differentiator as explainability, safe QR, and explicit uncertainty; avoid unsupported accuracy/novelty claims.	To do
Release	Resolve Must tests and document waivers; record remaining known issues.	To do

APPENDIX E — GLOSSARY

- Analysis result: score or Inconclusive state, risk band, findings, evidence sources, limitations, and recommendations.
- Degraded result: a result generated while an optional evidence source is unavailable.
- Evidence source: a local rule, model, or external provider contributing information.
- Rule version: identifier for the rules and configuration used for a result.
- Model version: identifier and hash for the approved ML artifact and its preprocessing pipeline.
- Unknown reputation: no usable current reputation verdict; it is not a benign verdict.
- Lookalike domain: a domain whose spelling or structure resembles a trusted brand/domain; resemblance alone is not proof of maliciousness.